UBKOracle Internal Audit Report

Oracle price resolution, invariants, usage modes, and failure analysis

UBKOracle Internal Audit

Scope: UBKOracle.sol and UBKOracleConstants.sol (as provided)

Prepared for internal engineering review ahead of beta tag (0.2.0).

Snapshot date	2025-12-23
Compiler	Solidity 0.8.20
Key dependencies	OpenZeppelin Ownable, Math; Chainlink AggregatorV3Interface; IERC4626; UBKDecimalsBounded
Oracle modes	NORMAL / PAUSED; per-token manual override

Disclaimer. Best-effort internal review only (not a formal security audit).

Contents

1. Executive summary

UBKOracle provides a deterministic pricing layer that normalizes prices to 1e18 precision and supports manual overrides, ERC-4626 vault share pricing, and Chainlink feeds. The design separates **cached reads** from **live updates** to keep hot paths predictable and cheap.

Key strengths

- Decimals are validated once at registration and cached (no runtime decimals() calls).
- Waterfall resolution includes guarded ERC-4626 pricing with recursion limits and sanity bounds.
- Staleness controls exist for both primary (Chainlink) and fallback (last valid) sources.
- Manual mode enables rapid response during feed outages and is bounded (when a recent last-valid exists).

Key risks / recommended follow-ups

- **Admin misconfiguration risk** is the dominant threat model: owner can set feeds, vault underlyings, and manual prices.
- ERC-4626 validation currently does **not** assert IERC4626(vault).asset() == underlying; a wrong mapping would misprice vault shares.
- Chainlink best-practice check for *answeredInRound* is not performed; this can accept incomplete rounds on some feeds.
- Default stale windows (24h feed, 48h fallback) are broad; for highly volatile assets, shorter periods may be appropriate.

Summary findings

Finding	Severity	Recommendation
ERC-4626 underlying not asserted	High	In _validateERC4626Vault, require IERC4626(vault).asset() == underlying to prevent misconfiguration-driven mispricing.
Chainlink round completeness not checked	Medium	Validate answeredInRound >= roundId (and optionally startedAt != 0) in _getChainlinkPrice.
Broad default staleness windows	Low	Consider per-asset stalePeriod tuning and a formal keeper cadence (e.g., refresh at least once per stalePeriod/2).